

Manual de Recuperação & Gestão de Senhas

Regras, Políticas de Segurança e Procedimentos (Paridade Android ↔ Web-PHP)

SISTEMA GESTÃO EPI

Objetivo: Mapear todos os fluxos de recuperação de senha, troca obrigatória de primeiro acesso, alteração voluntária e redefinição administrativa para replicar na aplicação **WEB-PHP**.

1. Regras Fundamentais de Segurança

- **Obrigatoriedade de Conexão (Online-Only):** A recuperação de senha via assistente **exige conexão com a internet**. Caso o dispositivo esteja offline, o sistema bloqueia o processo e exibe um alerta de segurança.
- **Política de Complexidade de Senha:**
 - Mínimo de **6 caracteres**.
 - Deve conter obrigatoriamente pelo menos **uma letra** (`[a-zA-Z]`) e **um número** (`[0-9]`).
 - Confirmação obrigatória (as duas senhas devem ser idênticas).
- **Hash de Armazenamento:** As senhas são criptografadas utilizando algoritmo `SHA-256` no banco local (Room) e no servidor MySQL.

2. Fluxo 1: Assistente de Recuperação de Senha (4 Etapas)

Etapa 1 — Identificação do Usuário

O usuário informa o login da conta. O sistema faz uma chamada assíncrona para validar se o usuário existe na base (`authRepository.verificarUsuarioExistente`).

Etapa 2 — Código de Verificação

O sistema valida o código de segurança enviando/conferindo o token numérico de 6 dígitos.

Etapa 3 — Redefinição de Senha

O usuário digita a nova senha e confirmação. O sistema aplica a validação regex de complexidade e executa a redefinição remota na API.

Etapa 4 — Confirmação & Auditoria

Atualiza o hash local no banco Room e grava o Log de Auditoria: `"Senha de operador redefinida com sucesso pelo assistente de recuperação."`.

3. Fluxo 2: Troca Obrigatória de Senha (Primeiro Acesso / Temporária)

Quando um usuário é criado ou resetado pelo Administrador, o sistema atribui a flag `exigir_troca_senha = true`.

Bloqueio de Navegação: Ao fazer login, se a flag `exigir_troca_senha` estiver ativa, o aplicativo redireciona imediatamente para a tela `TrocaSenhaObrigatoriaActivity` e proíbe a navegação no sistema até que uma nova senha seja cadastrada.

4. Implementação na Aplicação WEB-PHP

A. Validação de Senha em PHP:

```
function validarPoliticaSenha(string $senha): ?string {
    if (strlen($senha) < 6) {
        return "A senha deve conter no mínimo 6 caracteres.";
    }
    if (!preg_match('/[a-zA-Z]/', $senha) || !preg_match('/[0-9]/', $senha)) {
        return "A senha deve conter pelo menos uma letra e um número.";
    }
    return null; // Senha válida
}
```

B. Endpoint PHP de Redefinição de Senha ('recuperar_senha.php'):

```
<?php
session_start();
require_once 'AuditLogService.php';

$login = $_POST['login'] ?? '';
$novaSenha = $_POST['nova_senha'] ?? '';
$confirmarSenha = $_POST['confirmar_senha'] ?? '';

if ($novaSenha !== $confirmarSenha) {
    die(json_encode(['success' => false, 'message' => 'As senhas não coincidem.']));
}

$erroSenha = validarPoliticaSenha($novaSenha);
if ($erroSenha !== null) {
    die(json_encode(['success' => false, 'message' => $erroSenha]));
}

// Criptografia SHA-256 e atualização no MySQL
$hashSenha = hash('sha256', $novaSenha);

$stmt = $pdo->prepare("UPDATE usuarios SET senha_hash = :hash, exigir_troca_senha = 0 WHERE login = :login");
$stmt->execute([':hash' => $hashSenha, ':login' => $login]);

// Auditoria
$jsonLog = AuditLogService::gerarJsonLog(
    usuarioOperador: ['id' => $user['id'], 'login' => $login],
    tipoEvento: 'REDEFINIR_SENHA',
    resultado: 'SUCESSO',
```

```
        ocorrencia: 'Senha de operador redefinida com sucesso pelo assistente de recuperação.'  
    );  
  
    echo json_encode(['success' => true, 'message' => 'Senha alterada com sucesso.']);  
?>
```